

Brightcare_SOC2_Typell.pdf

Brightcare Digital Health · Confidential · For underwriting use only

SOC 2 TYPE II REPORT — SYSTEM DESCRIPTION & OPINION (EXCERPT)

Service organization: Brightcare Digital Health, Inc.

Report period: 2025-07-01 through 2026-06-30

Trust Services Criteria: Security, Availability, Confidentiality

Independent service auditor: Northline Assurance LLP (fictional demo firm)

Report date: 2026-08-22

CONFIDENTIAL — For underwriting and broker use only. Not for redistribution.

INDEPENDENT SERVICE AUDITOR'S REPORT (SUMMARY)

We have examined Brightcare's description of its Care Coordination Platform system and the suitability of design and operating effectiveness of controls throughout the period. In our opinion, in all material respects, based on the criteria described:

- (a) the description fairly presents the system;
- (b) controls were suitably designed;
- (c) controls operated effectively to provide reasonable assurance that the related TSC were achieved during the period.

Opinion: Unmodified (clean).

SCOPE HIGHLIGHTS

In scope: production AWS environments, Okta workforce IdP integrations, change management, logical access, encryption at rest/in transit, monitoring/alerting, backup/restore procedures, vendor risk for critical subprocessors (AWS, Okta, CrowdStrike, Microsoft).

Out of scope: corporate office Wi-Fi, marketing website CMS, Snowflake analytics workloads without ePHI.

CONTROL EXCEPTIONS / MANAGEMENT RESPONSES

- EX-01 Logical access — lagged deprovision for 2 contractor accounts (max 11 days). Management: automated Okta!HRIS sync completed 2026-05; retested with zero aged accounts in June sample.
- EX-02 Change management — emergency change without CAB pre-approval (1 of 42 sampled). Documented post-facto within 48h; no recurrence.

COMPLEMENTARY USER ENTITY CONTROLS (CUECs)

Customers must: (1) manage their own workforce access to Brightcare; (2) notify Brightcare of suspected account compromise; (3) configure federation IdP policies consistent with their HIPAA obligations.

SUBSERVICE ORGANIZATIONS

AWS — carve-out method; Brightcare monitors via Shared Responsibility matrix and AWS Artifact SOC reports (reviewed annually).

This excerpt is a demo underwriting package facsimile — not a live audit.